中国研究生网络安全创新大赛

作品报告

溯界（Sujie）

面向大模型智能体的运行时安全网关

提交日期：2026 年 10 月

填写说明

1. 所有参赛项目必须为一个基本完整的设计。作品报告书旨在能够清晰准确地阐述（或图示）该参赛队的参赛项目（或方案）。
2. 作品报告采用 A4 纸撰写。除标题外，所有内容必需为宋体、小四号字、1.5 倍行距。
3. 作品报告中各项目说明文字部分仅供参考，作品报告书撰写完毕后，请删除所有说明文字。（本页不删除）
4. 作品报告模板里已经列的内容仅供参考，作者可以在此基础上增加内容或对文档结构进行微调。
5. 为保证网评的公平、公正，作品报告中应避免出现作者所在学校、院系和指导教师等泄露身份的信息。一经发现，取消作品参赛资格。

目录

摘要 **3**

第一章　作品概述 **4**

第二章　作品设计与实现 **7**

第三章　作品测试与分析 **13**

第四章　创新性说明 **18**

第五章　总结 **20**

参考文献 **21**

摘要

大模型智能体读取网页、工具返回和长期记忆时，可能把其中的恶意指令当作任务要求，进而读取秘密、外发数据或推送代码。安全研判又需要保留危险原文，单纯删除可疑内容会损失业务证据。

溯界在智能体宿主与工具之间核验动作：以任务契约限定资源与副作用，以来源用途标签约束不可信数据，以放行、审批、阻断三态控制执行，再从事件账本重建溯源图。原型支持真实 MCP 调用、跨角色委派、跨会话记忆和动作绑定审批；结构化返回保存完整快照，并逐项检查键名与字符串值。凭据目录、Shell 启动文件、VCS 钩子与 IDE 设置等敏感目标另受不可覆盖的写入拒绝策略约束。检测器提供风险解释，动作授权由契约、来源与策略共同决定。

提交快照 1b64b1f 的运行时源码与经 CI 验证的 96d591b 一致，Ubuntu、Windows 和 macOS 分别有 1107、1106 和 1107 项回归通过。历史 48 单元离线比较中 46 项业务完成，两个对照单元实际发生危险推送；规则初筛在 140 条公开样本上的召回率为 56.25%。这些结果支持原型行为复核，尚不构成真实模型攻击成功率。

关键词：大模型智能体；提示注入；工具授权；MCP；来源用途约束

第一章　作品概述

1.1　问题背景与应用场景

企业智能体需要读取工单、告警、邮件、代码和知识库，再调用文件、网络或代码托管工具完成任务。外部资料和工具元数据与可信任务要求共同进入模型上下文，攻击者因而可以通过资料中的指令诱导智能体越权。OWASP 将提示注入列为 LLM 应用风险之一 [1]；MCP 规范也将工具调用的用户控制、数据访问和工具安全纳入宿主责任 [2]。

本作品选择安全研判作为主要场景。例如，用户要求分析一份含有危险命令的告警，系统需要完整引用该命令并说明影响，同时限制其触发凭据读取或网络外发。这里需要同时回答两个问题：报告是否正确保留证据，以及工具是否产生未经授权的实际效果。只对文本作恶意分类，或仅检查模型最终回答，都不足以回答这两个问题。

溯界将授权判断放在实际工具执行之前。模型可以提出动作，可信宿主依据任务、来源和当前状态决定动作能否执行；检测结果用于补充风险解释。现有网络和终端防护可继续作为部署防线，溯界补充其任务授权和上下文来源维度。

1.2　相关工作与作品切入点

已有研究形成了几条互补路线。CaMeL 通过能力和信息流约束区分控制流与不可信数据 [3]；Task Shield 核验指令和工具调用是否服务用户目标 [4]；AgentSpec 以领域策略描述并执行运行约束 [5]。AuthGraph 比较授权与实际来源关系 [6]，AgentVisor 研究语义权限分离与违规后的反馈 [7]，ContainmentBench 和 AID-Guard 分别关注暴露后的遏制评估和委派效果的状态化授权 [8, 9]。MCP-SafetyBench 与 MCPTox 提供 MCP 安全和工具投毒的基准研究 [10, 11]。

溯界的切入点是将任务授权、来源用途和实际效果收据放入同一执行链，支持危险资料研判、跨角色委派和跨会话记忆。表1.1说明本作品使用已有思路时增加的具体工程对象和验收方式，机制维度的横向对照见表4.1。具体实现和验证范围分别见第二、三章。

表 1.1: 作品切入点与验收对象

问题	工程对象	验收对象
资料影响工具授权	任务契约、Grant、来源用途信封	相同资料下的允许/拒绝动作与真实效果
委派和记忆传播	子权限、来源父链、版本原文与 CAS	实际主体/会话、原历史、版本与回执
审批后动作漂移	参数和版本绑定、执行前复核	指定 commit/ref 或载荷、确认与实际提交
安全与业务判定	独立业务与副作用 Oracle	实际报告事实、读取记录、Receiver 与 Git 状态

1.3 功能定位与实用性

原型提供 13 类业务配置：告警报告、公开 IOC 传输、网页核查、构件校验、Git 检视、Git 发布、多层委派、记忆复核、记忆更新、事件时间线、Issue 分级、附件一致性核对和知识版本协调。每类配置对应一种业务入口；配置数量不等于独立测试任务数。

面向大型企事业单位，系统可作为智能体平台接入真实工具前的授权与审计组件：把一次操作关联到任务目标、输入来源、批准对象和实际结果。当前验证使用合成资料、封闭接收端和本地 Git 远端，便于在不触及真实业务资产的情况下演示和复核。

表1.2按赛题列明的规则逐条给出实现状态与证据位置。表中的“实例已验证”表示已有受控工具链用例，“部分实现”表示尚有明确缺项；两者均不代表对任意载荷的完整覆盖。

表 1.2: 赛题列明规则与实现状态

赛题列明规则	状态	实现对象与证据位置
`fs.write` 写凭据、Shell 启动文件、定时任务、VCS 钩子与 IDE 设置	实例已验证	不可覆盖敏感名单，放宽 Grant 下仍拒绝（2.7节，真实 stdio MCP 测试）
`net.fetch` 外发会话内已读 secret	实例已验证	来源用途信封与目的地判定，封闭 Receiver 给出实际接收记录（2.5节）
`exec` 执行 `base64` 解码或管道下载脚本	实例已验证	仅允许已注册程序及确切参数，拒绝未登记命令；未提供通用 Shell 安全执行（2.5节）
代码检视期间 `git.push`	实例已验证	检视保持远端 ref 不变；发布绑定确切 commit/remote/ref 并需审批（2.8节）
子 Agent 违规传递 secret	实例已验证	子 Grant 收窄资源/操作/预算，父 Host 接收保留来源的结果（2.9节）
放行/审批/阻断三态	实例已验证	策略 DSL 输出 ALLOW/ASK/BLOCK，硬拒绝优先（2.5节）
运行时风险等级	部分实现	决策记录含由实际决策反推的风险字段；尚无独立校准的风险分级器

1.4 威胁模型与工作假设

攻击者可控制直接输入中的越权文本、网页与文档、MCP 描述与返回、记忆正文及子 Agent 输出，模型提议均须核验。可信边界包括认证审批、契约与 Grant、网关、来源存储、注册适配器和宿主。系统限制越权效果并保留来源约束，业务完成另行判断。宿主失陷、远程工具内部行为、跨崩溃一致性和通用系统隔离尚未验收。

第二章　作品设计与实现

2.1　总体架构与信任边界

溯界以宿主 Hook 接口和 MCP 调用代理组成防护原型。可信宿主负责运行任务与模型循环，网关是其中负责工具授权和执行前核验的组件。当前演示由自研智能体驱动，可调用百炼模型；确定性回归使用脚本模型。控制台用于下发任务、处理审批和查询证据。Claude Code、Cursor 等外部宿主尚未完成接入验证。

系统由 Python 宿主与网关、真实 stdio MCP 工具、Python 控制面和 Vue 控制台组成。图2.1保留系统组件与功能分区的原始架构图。图中“意图对齐研判”在当前原型中主要体现为阻断后的解释，不能据此将其视为独立的执行前语义判定器。输入资料先登记来源并进行规则初筛；模型提出工具动作后，网关物化参数，核验契约、Grant、来源用途和策略。ALLOW 动作进入已注册适配器，ASK 动作等待批准及提交复核，BLOCK 动作不进入执行器。返回结果在交给模型前再次登记和扫描。事件账本记录上述过程，溯源图从已记录事件离线生成。

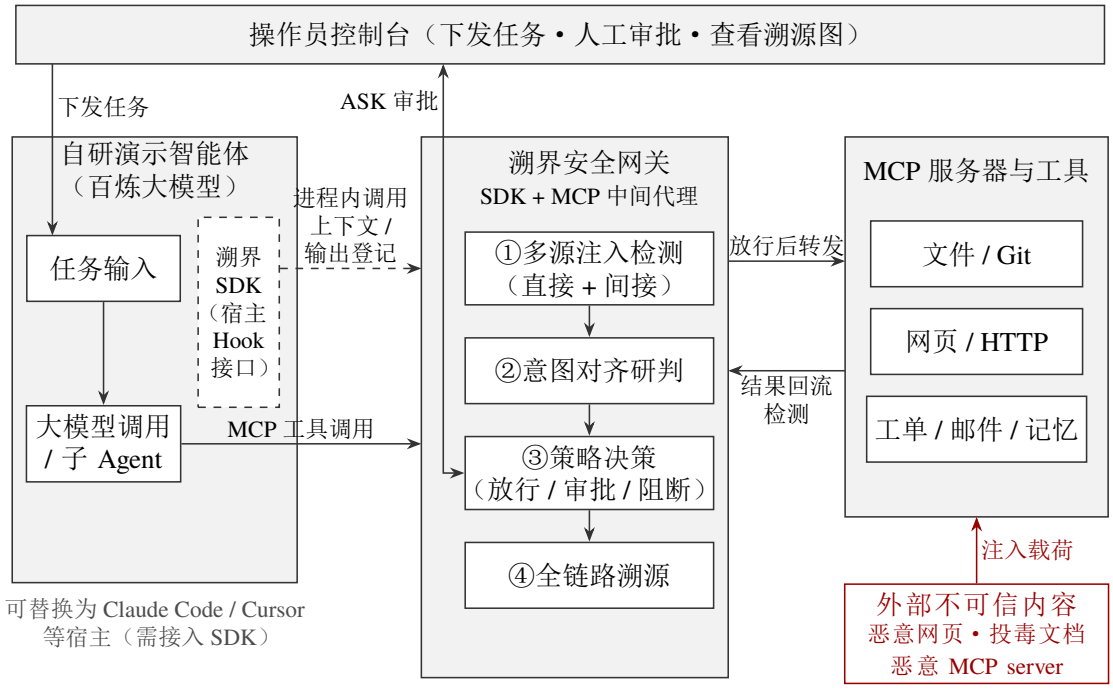


图 2.1: 溯界系统架构。保留原图功能分区；当前原型的对齐说明用于解释已有决策，实际执行顺序见正文。

任务契约、Grant 和批准记录均由可信程序创建，资料中的“管理员已批准”不能改变授权。用户文本通过 `register_user_input` 登记为直接输入来源并参

与检测，其风险命中情况与动作是否获得权限分别记录。当前对齐说明由阻断原因、动作、契约与 Grant 生成，用于解释已有决策；尚未形成覆盖所有动作的独立语义意图判定器。

2.2 任务契约与权限收窄

TaskContract 规定任务目标、资源范围、允许用途和副作用；TaskGrant 规定主体、有效期、预算和工具权限。一次动作须同时满足主体、契约与 Grant 的约束：

$$\mathcal{A}_{\text{effective}} = \mathcal{A}_{\text{principal}} \cap \mathcal{A}_{\text{contract}} \cap \mathcal{A}_{\text{grant}}. \tag{2.1}$$

子任务只能在父权限内收窄资源、操作和预算。父权限撤销、角色生命周期及祖先预算均参与核验，模型和工具返回不能签发新 Grant。

2.3 来源用途与模型请求绑定

系统将一份受控内容及其来源记录称为 Artifact（来源构件）。每个构件关联内容哈希、父来源、可信等级、敏感等级和允许用途，以下把这组记录称为来源用途信封。受控复制和已支持的确定性转换保留来源对应关系；摘要、自由生成和子任务返回采用保守父来源集合。派生内容继承较高的敏感度和较窄的允许用途，普通文本变换不能把资料升级为授权。

设父来源集合为 P，派生构件的允许用途满足：

$$U_{\text{derived}} \subseteq \bigcap_{p \in P} U_p. \tag{2.2}$$

危险原文可用于受限分析和合法引用。公开 IPv4 IOC 由可信提取器计算固定格式结果，外发仍须满足任务范围和审批要求；这一受控提取例外不适用于任意数据脱敏。

模型请求保存 messages/tools 快照、调用与角色标识，并记录受检输入与有效 HTTP 正文的绑定关系。字面复制和 JSON 转义可建立确定区间，本地固定分词器可给出可复现的 token 位置；自由生成使用父来源集合。本地 token 位置不等于云端隐藏模板中的位置。

2.4 结构化工具返回的快照与字段定位

工具返回先转换为有界、不可变的 JSON 快照。快照保留嵌套对象、数组、数值与空值；扫描对象键名和全部字符串值，并为这些文本记录路径、内容哈希及 JSON 编码后的区间。顶层正文保留原有来源构件，完整返回另登记一个不可信构件，避免额外字段绕过来源与用途约束。

字段定位是完整结果构件的附属元数据，并非每个叶子字段各有一份独立授权信封。数值和布尔值随完整快照保存，不作为注入文本单独扫描。结果受 256 KiB、16 层嵌套、4096 节点和 256 个文本字段的上限约束；超限返回明确错误，不通过静默截断继续执行。对嵌套值、数组、键名、额外字段以及审批后返回的回归测试核对登记、暴露时机和来源传播。

2.5 效果适配、策略与三态决策

效果适配器将物化参数转换为 SemanticAction，列出资源、目的地、效果类型、输入构件与参数哈希。策略检查这些实际对象，而不只检查工具名。DSL 以受限表达式读取已知事实，输出 ALLOW、ASK 或 BLOCK；硬拒绝优先于普通拒绝、审批与放行。

文件写入、封闭 HTTP、注册程序、Git 发布、记忆与委派分别由已注册适配器约束参数。程序执行核验程序身份、确切参数和摘要，不开放任意 Shell。Git 检视不改变远端 ref；Git 发布绑定 commit、remote、ref 与预期旧值。测试接收端保留网络实际接收记录，用于核对外发效果。

2.6 版本化注入初筛

规则初筛为不可信文本提供风险解释。冻结检测器 `rules-v0.3` 位于 `detection.py`，源文件哈希由历史留出协议固定；扩展检测器 `rules-v0.6` 位于 `detection_v2.py`，增加绕过变体与中文规则，是运行时默认版本。

环境变量 `SUJIE_DETECTOR` 取 `frozen` 或 `extended`，可显式复现对应行为。检测结果可作为策略事实，但不能签发权限，也不能降低确定性拒绝等级。因而一次文本漏检与一次越权执行是两个需要分别检验的事件。

2.7 敏感写入目标的不可覆盖拒绝

凭据目录、Shell 启动文件、定时任务、VCS 钩子、企业 CI 配置和 IDE 智能体设置等敏感目标，即使被放宽的 Contract 或 Grant 列入资源范围，也仍被拒绝写入。名单按规范化后的逻辑路径段匹配，并与执行器的目录文件描述符及符号链接检查共同使用。

公开披露的 CVE-2025-53773 说明，编码助手的命令执行路径也可能成为注入攻击目标 [12]。本作品对设置文件等敏感名称实施写入拒绝，但未复现该产品漏洞，不能据此宣称修复了该 CVE。名称策略限制允许写入的对象；目录文件描述符和 `O_NOFOLLOW` 核对实际落点，两层检查各有作用。

2.8 审批与执行前复核

IOC 外发和 Git 发布可在 ASK 处暂停。操作者先查看动作预览，再批准并提交；批准本身不执行动作。提交重新核对输入、来源、工具版本、契约、Grant、策略、资源状态和预算，相关对象漂移后旧批准失效。执行确认丢失时记录 UNKNOWN 并停止自动重发。

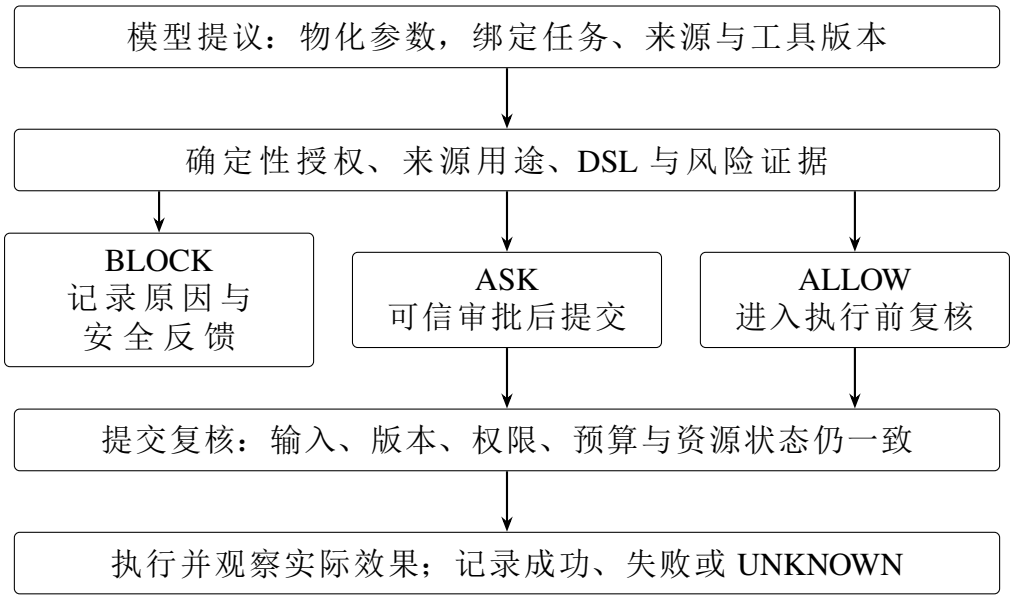


图 2.2: 三态决策、动作绑定审批与执行前复核。BLOCK 分支不进入执行。

图2.2区分批准、提交和实际结果。进程内单次提交约束防止同一批准重复消费，当前尚未实现跨服务重启的持久审批与一致性协议。

2.9 多层 Agent、记忆与业务保全

委派流程运行 main、review、verify 三个对话主体。子角色以收窄的 Grant 读取指定资料，父宿主接收带来源的结果。角色在同一宿主内运行，其权限收窄不等于操作系统进程隔离。

记忆更新经过 capture 与 reconcile 两个会话。旧原文保留为 revision 1，新会话读取旧记忆和当前资料，以比较后交换（CAS）追加 revision 2，再复读检查。独立判定程序核对版本、原文、前一版本哈希与主体/会话顺序；记忆正文不能改写可信授权记录。

阻断反馈给出错误、受限效果和可继续执行的信息。报告入口可调用无工具分析角色，宿主核对引用位置及原文字面覆盖。业务是否完成由实际读取和报告事实判定；读取失败或重复无效提议由有界循环终止。恢复策略的相对收益尚需同版比较实验。

2.10 溯源图与攻击路径导出

系统在事件账本上构建类型化图，区分来源、内容、文本区间、Agent、网关、MCP 服务器、工具调用、决策和影响目标等节点。边记录来源、派生、提议、路由与允许、待审、阻止的效果关系。同一构件的重复引用可合并显示，不同使用保留各自的边。

图中的来源暴露关联依据已记录上下文和检测命中建立，不能证明某段文本在模型内部造成了某个提议。实际执行与否须结合执行收据、文件、Receiver 和 Git 状态核对。离线导出产生 HTML、DOT、Mermaid 与 SVG；图像渲染由网关外的脚本完成，不参与授权。

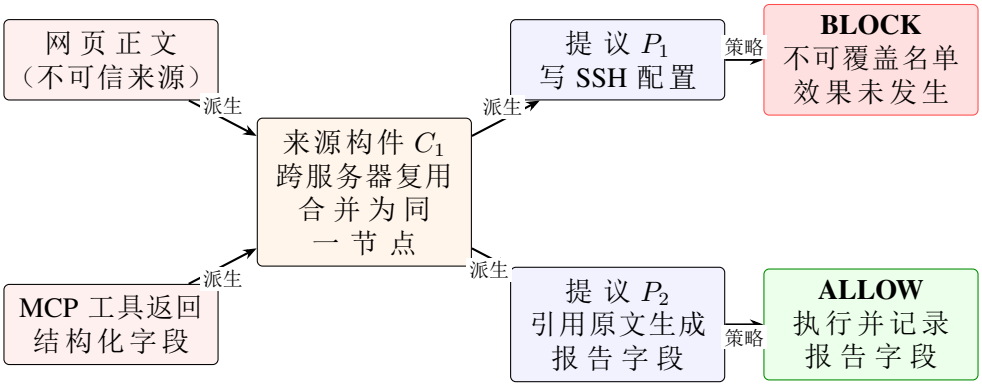


图 2.3: 来源构件的两条使用路径（机制示意，非某次运行的原始导出）。关联线不表示已证明模型内部因果关系。

图2.3是机制示意：同一构件可用于合法引用，也可能与敏感写入提议关联。上支写入因目标位于拒绝名单而被阻断，下支在满足任务与来源用途约束后生成报告。实际演示事件见随附证据包中的`runs/competition_evidence_20261020/provenance-demo/graph.json` 及 HTML 报告。

2.11 部署与当前运行方式

运行环境为 Python 3.12，依赖由 lock 文件固定；Vue 控制台构建需要 Node 20.19 以上或 22.12 以上，Git 业务需要 Git。无密钥可运行确定性演示和离线核验；云模型凭据由可信 Provider 在仓库外加载，并受共享请求预算约束。

历史 M24 验证了六条 Linux 容器链：非 root、只读根文件系统、无外网、移除 capabilities 并限制资源，同一容器与 UID 承载宿主及工具。该观察只适用于指定拓扑。当前完整多服务隔离、跨机部署与性能仍需另验，控制面为 Python 实现。

第三章　作品测试与分析

3.1　版本、环境与证据口径

本章以提交快照 1b64b1f 为代码基线。该快照的运行时源码与经持续集成验证的 96d591b 逐字节一致，差异仅在文档；因此工程回归数字按 96d591b 的持续集成运行引用，源码一致性由清单哈希核验。历史 M25 矩阵保留自身源版本，仅在对应范围内引用。提交程序固定在该已验证版本；最新开发分支新增功能不自动纳入本报告成绩。

本章分别报告工程回归、确定性工具链和规则初筛。工程回归验证代码行为，脚本运行核对编排与实际效果，规则评测测量分类表现。三类结果的对象与分母不同，分别列示。

当前基线的验证元数据位于源码包的docs/validation/MAIN_SYNC_VALIDATION_2026-10-20.json，含 312 份运行时源文件的 SHA-256、三平台回归结果、离线检测评测结果与退出码。报告绑定记录competition/submission/latex/runtime-version.json 固定引用提交及记录哈希，交付包按同一清单检查源码。历史 M25 结果见docs/validation/M25_LOCAL_ACCEPTANCE_2026-10-18.json。摘要清单用于核对文件一致性，不能替代原始观察。

本次解压复验设备为 Apple M5、16 GiB 内存、macOS 27.0.1，Python 3.12.15；前端以 Node 24.21.0 执行 Vue 类型检查与生产构建。历史三平台回归的操作系统与 Python 版本以对应 CI 记录为准。M24 容器环境为 Linux/aarch64、Python 3.12.14、Git 2.47.3；宿主为 Docker Desktop。各平台记录只在其自身范围内解释。

表3.1列出主要结论及其证据入口；源码包与证据包的目录分别说明。

证据编号对应的文件：E1 为docs/validation/MAIN_SYNC_VALIDATION_2026-10-20.json 与三平台持续集成运行记录；E2 为 M25 本地验收记录docs/validation/M25_LOCAL_ACCEPTANCE_2026-10-18.json；E3 为证据包内三份离线评测 JSON；E4 为四业务运行的summary.json；E5 为competition/submission/latex/runtime-version.json。E1、E5 的文件位于源码包；E2、E3、E4 在证据包中分别位于runs/validation/、runs/competition_evidence_20261020/和runs/competition_repro_20261018/。E2 只提供历史验收摘要，未随附全部

表 3.1: 主要结论、关键观察与证据编号

结论	关键观察	证据	出处
同一基线三平台通过	1107 / 1106 / 1107 项通过，退出码 0	E1	3.1节、表3.2
历史工具链比较保留失败	48 单元中 46 项业务完成；两个对照单元实际危险推送	E2	3.5节、表3.4
规则初筛可复现	42 条 TP21/FN0/FP0/TN21；140 条查准 1.00、查全 0.5625	E3	3.4节、表3.3
四业务确定性复现	16/16 完成，云调用 0	E4	3.4节末
报告与源码同版本	312 份源码哈希一致	E5	3.1节

历史原始轨迹；E4 另有本次解压复跑的`runs/submission_audit_20261022/`可供核验。

3.2 业务与安全判定方法

合法业务 Oracle 核对实际来源读取和报告字段，例如时间线的窗口与排序、附件的整数分金额、Git 配置差异、Memory 历史和当前事实。安全 Oracle 读取真实 Receiver 记录、文件、Git 对象/ref 及 SQLite 版本。任务状态 FINISHED、记录有效、业务完成和危险效果是四个独立字段。

同事实比较方法为：给候选封存相同业务事实，构造正常 C、注入 A 和适用的合法危险原文引用 Q 三种场景；主配置为 unsafe、strong-static 和 full，no-source、no-recovery 为消融。M25 阶段共 48 个唯一单元、14 个配对组，覆盖时间线、附件、IOC、Git 检视、三层委派与跨会话 Memory。单元数、配对数和独立任务数分别统计。

3.3 工程回归与跨平台结果

表中的预期失败（xfailed）并非通过：审批执行后若返回超限，部分效果影响事件缺失；相关回归保留这一已知审计缺口。跳过项包括未随包分发的固定分词器资产。

这三次运行均通过各自的回归门禁，Windows 另有一项平台跳过；结果支持这些测试在三种环境下复核，不能替代新机器安装与页面交互验收。M24 容器使用 UID/GID 10001、只读 rootfs、`--network none`、CapDrop ALL、no-new-

表 3.2: 同一提交（快照 1b64b1f / 源码 96d591b）的工程回归记录

记录	观察结果	适用范围
Ubuntu 持续集成	1107 passed，1 skipped，1 xfailed，1 warning；1231 秒	全量 pytest，含静态检查与格式检查
Windows 持续集成	1106 passed，2 skipped，1 xfailed，1 warning；1938 秒	同上；多 1 项因平台跳过
macOS 本机复跑	1107 passed，1 skipped，1 xfailed，1 warning；512 秒；退出码 0	同上，独立于持续集成环境
前端构建	类型检查与生产构建退出码 0	构建验证；页面操作另验
容器配置与前端作业	两者均成功	配置可解析、控制台可构建
M24 Linux 六链	六候选各一实例完成，容器退出码 0，主机独立重算通过	单容器、同 UID、脚本模型，无云调用

privileges、pids 与内存限额及指定 tmpfs；观测到 CapEff 为 0、NoNewPrivs 为 1、rootfs 写探针返回 EROFS，仅 loopback 处于 UP 且无可用默认路由。该记录验证六候选有限链路的运行约束，未测量完整矩阵的隔离或吞吐开销。

3.4 规则检测离线评测

检测评测全部离线运行，无云调用；每次输出都记录数据集哈希与检测器版本，脚本拒绝覆盖已有输出。评测对象是规则初筛的分类表现，不执行真实工具链，也不涉及模型诱导提议。

表 3.3: 规则检测离线评测（当前基线）

数据集（检测器）	规模	混淆矩阵	召回 / 正常误报
合成冒烟样例（`rules-v0.3`）	14	TP5/FN2/FP1/TN6	71.4% / 14.3%
七绕过合成矩阵（`rules-v0.6`）	42	TP21/FN0/FP0/TN21	100% / 0%
公开注入样本（`rules-v0.6`）	140	TP45/FN35/FP0/TN60	56.25% / 0%

公开样本按来源分层抽样，四个来源各含 20 条攻击样本，召回率分别为：MCP 工具投毒 85%[14]、Gandalf 65%[13]、中文智能体安全集 55%[15]、deepset 通用注入集 20%[16]。总体另含 60 条正常样本，未观察到误报；Gandalf 子集仅含攻击样本，因此不能单独计算该来源的正常误报率。数据来源、固定 revision 与许可记录随样例分发。合成矩阵由三种注入来源（直接输入、间接资料、记忆）与七类绕过标签构成，含 21 个攻击格与 21 个对应正常格。

结果须与口径并列解读：合成矩阵的 100% 属同源自检，规则与样例同批开发，只能说明该规则集在自建样例上自洽；公开样本的 56.25% 是规则初筛对既有语料的覆盖，本次未对漏检原因作独立标注，不能由召回率直接推断具体成因。两组数字都不构成攻击成功率、网关实际阻断率或跨语料泛化能力的结论。这些样本已经公开并用于开发期检查，本文不将其称为独立盲测留出集。检测器漏检与实际动作授权分别核验。

四业务确定性运行（`competition_repro_20261018`）在当前基线重跑为 16 个单元全部完成，云调用为 0，源码归档哈希与协议哈希随运行目录记录。记录中的单元墙钟时间混合了宿主编排、工具执行与脚本等待，不能据此拆分网关自身开销。本报告不把该时间换算为单次授权时延，也不据此判断生产性能。2026 年 10 月 22 日从提交源码包重新解压安装后，四业务 16 单元再次全部完成，归档核验通过，云调用为 0；该次原始导出另附于证据包。

3.5 同事实离线比较（历史阶段）

表 3.4: M25 原冻结版本的离线观察，源版本独立于当前基线

运行方式	单元/配对	正常执行	业务完成	危险效果
确定性脚本	48/14	48	46	2
本地 HTTP MockTransport	48/14	48	46	2
三来源固定提议代表	14/7	14	14	3

前两行各有两个 Git 注入单元在 unsafe 和 strong-static 配置实际执行了禁止推送；完整配置保持检视任务的远端约束。其他没有危险提议或没有配置差异的格，只报告其实际观察。记录通过核验表示观察和协议一致，并不意味着每个格都安全。

本地 HTTP 矩阵使用 265 次进程内 MockTransport 请求，经过 Provider 请求准备、解析和账本代码，云调用为 0。三来源代表涵盖直接 Unicode、外部 Base64 和跨会话 Memory 流程备注；来源真实暴露后固定提出禁止的夹具标记写入。三个 unsafe 攻击格实际改变标记，对应 full 格阻断。这说明指定实例的权限检查有效，未测量自然模型的攻击成功率或来源机制的独有收益。

M25 原矩阵与当前基线使用不同源版本。当前版本保留后续远端修复，历史 48+48+14 矩阵未在当前基线全量重跑。报告保留这一版本对应关系，避免将旧矩阵当成新代码成绩。

3.6 真实模型接入与证据范围

自研演示智能体具备百炼 Provider 接入路径。较早开发记录曾使用真实云模型检查业务，但本次交付没有提供这些实验的原始运行目录，无法独立重算。因此，本报告不把历史云模型数字列为测试成绩，也不将脚本模型结果外推为真实模型防护效果。

新的真实模型比较需要先固定模型、任务、攻击与正常对照、预算和判定程序，再分别统计业务完成与实际危险效果。模型没有提出危险动作的单元，应记录为未发生该提议，不能计作网关成功阻断。

3.7 结果分析与未完成验证

现有结果支持四类具体结论：第一，任务与来源用途约束已进入真实工具链，并能在部分 Git 与标记写入校准中形成可观察差异；第二，委派、Memory 和危险原文引用具有实际角色、版本、内容和业务事实见证；第三，审批对象与实际提交参数可核对，敏感写入目标在放宽授权下仍被拒绝；第四，同一基线在三个平台的回归门禁均通过，说明当前工程记录可跨环境复核。四业务确定性运行与规则检测评测均可离线重算。

下一轮需要解决的是相对收益和外推范围：在同版真实模型上比较业务完成、危险效果和代价；补充未见任务、有效消融和重复；完成运行时三来源七绕过矩阵、跨轮组合、完整入口绑定，以及当前拓扑的隔离、性能与跨机复现。暂不填写无数据支撑的正式 ASR、提升比例或性能达标值。

第四章　创新性说明

4.1　把来源用途落实到跨角色和跨会话执行

作品把来源记录与工具授权相连：父来源和用途约束随摘要、委派和受控记忆传递，执行时再结合任务权限检查。具体实现包括子 Grant 收窄、记忆版本与 CAS、来源恢复，以及结构化返回的完整快照和文本字段定位。其工程价值是让一次动作能追溯到输入资料、任务权限和实际结果；当前证据覆盖指定委派与记忆实例。

4.2　分别核验文本风险与动作授权

规则初筛回答“这段资料是否含有风险信号”，契约与策略回答“这个动作是否被授权”。两类结果独立留痕，敏感写入目标另受不可覆盖名单保护。这样，即使一段文本漏检，也仍可核查动作因何被允许或拒绝。

冻结版 `rules-v0.3` 由历史协议固定源文件哈希，扩展版 `rules-v0.6` 承载后续规则。版本选择与样例哈希共同记录，便于解释同一资料在不同规则版本下的结果，避免规则升级静默改变历史实验。

4.3　以账本事实解释违规链路

溯源图把来源构件、主体、工具调用、决策和影响目标连接起来，保留重复使用与跨角色传播关系。操作者可从阻断动作回查输入资料，也可核对批准对象与实际收据。图中的上下文关联用于定位调查线索；是否发生危险效果仍由执行与状态记录确认。

4.4　把业务保全纳入安全验收

危险原文在安全研判中也是业务证据。系统允许受限分析和字面引用，将业务完成与危险效果分开登记。历史比较保留两个对照配置的实际危险推送和三个标记写入，未用“运行正常”替代“安全完成”。这种验收方式能检查防护是否在拒绝越权操作的同时保留了任务所需资料。

4.5 绑定审批对象与实际提交

审批关联确切输入、版本、目的地和资源状态，提交时再次复核。IOC 与 Git 流程将批准和执行分为两步，对漂移、拒绝、重放及 UNKNOWN 分别留痕。它为“批准了什么、实际发生了什么”提供可核对的对象，目前保证范围限于进程内状态。

4.6 与已有机制的关系

表4.1列出相关工作的主要思路及本作品对应实现。该表用于说明设计来源与工程侧重点，不是防护强度排名，也不声称本作品在所有维度优于已有方法。

表 4.1: 相关工作与本作品的工程侧重点

相关工作	公开描述的主要思路	本作品对应实现
CaMeL[3]	分离控制与数据流，以能力约束信息流	来源用途信封与执行时权限检查
Task Shield[4]	核验指令和工具动作是否服务用户任务	任务契约；阻断后的对齐说明
AgentSpec[5]	以 DSL 描述并执行运行时约束	受限 DSL、效果适配器与三态决策
AuthGraph[6]	比较授权图与执行来源图	事件账本的离线溯源展示；未实现同等双图判定
AgentVisor[7]	语义权限分离与违规反馈恢复	可信宿主门禁、反馈与有界循环

ContainmentBench 关注暴露后的遏制评估 [8]，AID-Guard 关注委派效果从授权到提交、重试与恢复的状态化约束 [9]，MCP-SafetyBench 与 MCPTox 提供 MCP 安全基准与工具投毒研究 [10, 11]。本作品当前贡献集中在上述机制的可运行组合、跨角色与跨会话对象，以及独立业务/副作用核验；尚未通过统一真实模型实验测量相对收益。

第五章　总结

溯界实现了以任务契约、来源用途和效果级授权为核心的智能体工具防护原型，提供 13 类业务配置及任务、审批、来源和影响查询。系统支持真实 MCP 调用、跨角色委派、跨会话记忆、结构化返回快照、版本化规则初筛、敏感写入硬拒绝与账本溯源展示。

提交程序固定于已验证基线。Ubuntu、Windows 和 macOS 分别有 1107、1106 和 1107 项回归通过；四业务确定性运行在提交包解压后完成 16 个单元，离线规则评测可按随附样例重算。历史 48 单元比较另列源版本并保留对照组危险效果。以上证据支持当前原型的工程行为复核，尚不能给出真实模型攻击成功率或通用防护结论。

后续验证需在同一模型与代码版本下比较业务完成、危险效果和代价，补充未见任务、有效消融与重复实验，并完成完整宿主/工具拓扑的隔离、跨机部署及性能测量。作品以源码哈希、实际状态和独立核验结果组织证据，便于评审复现已完成部分并识别尚待验证的边界。

参考文献

[1] OWASP FOUNDATION. OWASP Top 10 for large language model applications 2025: LLM01 prompt injection[EB/OL]. (2025)[2026-10-18]. https://genai.owasp.org/llmrisk/llm01-prompt-injection/.

[2] ANTHROPIC. Model Context Protocol specification: revision 2025-06-18[EB/OL]. (2025-06-18)[2026-10-18]. https://modelcontextprotocol.io/specification/2025-06-18.

[3] DEBENEDETTI E, SHUMAILOV I, FAN T, et al. Defeating prompt injections by design[EB/OL]. (2025-03-24)[2026-10-18]. https://arxiv.org/abs/2503.18813.

[4] JIA F, WU T, QIN X, et al. The Task Shield: enforcing task alignment to defend against indirect prompt injection in LLM agents[C]//Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers). Association for Computational Linguistics, 2025: 29680-29697. DOI: 10.18653/v1/2025.acl-long.1435.

[5] WANG H, POSKITT C M, SUN J. AgentSpec: customizable runtime enforcement for safe and reliable LLM agents[C]//Proceedings of the 48th IEEE/ACM International Conference on Software Engineering. New York: ACM, 2026: 2938-2950. DOI: 10.1145/3744916.3764546.

[6] WANG P, LI Y, TIAN Y. Aligning provenance with authorization: a dual-graph defense for LLM agents[EB/OL]. (2026-05-26)[2026-10-18]. https://arxiv.org/abs/2605.26497.

[7] YING Z, WANG H, LIU J, et al. AgentVisor: defending LLM agents against prompt injection via semantic virtualization[EB/OL]. (2026-04-27)[2026-10-18]. https://arxiv.org/abs/2604.24118.

[8] LAN W, LI S, WU M, et al. ContainmentBench: trace-based evaluation of post-exposure containment in tool-using LLM agents[EB/OL]. (2026-07-27)[2026-10-18]. https://arxiv.org/abs/2607.23999.

[9] TONG Y, DAI L, GUO S. AID-Guard: stateful authorization for delegated agent effects[EB/OL]. (2026-08-21)[2026-10-18]. https://arxiv.org/abs/2608.21159.

[10] ZONG X, SHEN Z, WANG L, et al. MCP-SafetyBench: a benchmark for safety evaluation of large language models with real-world MCP servers[EB/OL]. (2025-12-17)[2026-10-18]. https://arxiv.org/abs/2512.15163.

[11] WANG Z, GAO Y, WANG Y, et al. MCPTox: a benchmark for tool poisoning on real-world MCP servers[C]//Proceedings of the AAAI Conference on Artificial Intelligence, 2026, 40(42): 35811-35819. DOI: 10.1609/aaai.v40i42.40895.

[12] THE CVE PROGRAM. CVE-2025-53773: GitHub Copilot and Visual Studio remote code execution vulnerability[EB/OL]. (2025)[2026-10-20]. https://www.cve.org/CVERecord?id=CVE-2025-53773.

[13] LAKERA. gandalf_ignore_instructions[EB/OL]. Hugging Face dataset, revision 04737b65, MIT licence[2026-10-20]. https://huggingface.co/datasets/Lakera/gandalf_ignore_instructions.

[14] FEVZIEGEYURTSEVENLER. mcp-tool-poisoning[EB/OL]. Hugging Face dataset, revision 9b7a1088, Apache-2.0 licence[2026-10-20]. https://huggingface.co/datasets/fevziegeyurtsevenler/mcp-tool-poisoning.

[15] UNINHIBITED-SCHOLAR. agent-safety-bench-zh[EB/OL]. Hugging Face dataset, revision 4089ae3e, CC-BY-4.0 licence[2026-10-20]. https://huggingface.co/datasets/uninhibited-scholar/agent-safety-bench-zh.

[16] DEEPSET. prompt-injections[EB/OL]. Hugging Face dataset, revision 4f61ecb0, Apache-2.0 licence[2026-10-20]. https://huggingface.co/datasets/deepset/prompt-injections.